

CODE VS. CODE

How Law Shapes System Architecture

GDPR · DPDP · HIPAA · Section 230 · EU AI Act — context, mechanics, real fines, and the proportionality test that runs through all five

GDPR

DPDP

HIPAA

§230

AI Act

August 2026

Necessity & Proportionality

- Key underlying question: when is it legitimate for a state or a company to collect, process, or restrict access to personal data? Courts and regulators answer that with a standard borrowed from human-rights law (ECHR Article 8, EU Charter Article 52(1)).
- **Necessity** — is this specific measure actually required to achieve the stated goal, or would a less intrusive alternative work just as well? A national biometric database is not “necessary” for tax collection if a less invasive ID system would do.
- **Proportionality** — even if a measure is necessary in principle, does the scale of the intrusion match the seriousness of the goal? Collecting a citizen’s fingerprints to issue a library card fails proportionality even if it would technically “work.”
- India’s Supreme Court formalized this into a fourfold test in Puttaswamy (2017): (1) legality — a law must actually authorize the measure; (2) legitimate aim; (3) necessity and proportionality — the least restrictive means, proportionate to the goal; (4) procedural safeguards against abuse. You’ll see this test applied directly to Aadhaar shortly.
- *Keep this test in mind for any law — nearly every major critique of GDPR, DPDP, and the AI Act comes down to a claim that some provision fails necessity, proportionality, or both.*

What Actually Drove the GDPR?

- GDPR was negotiated from 2012 to 2016, and two real-world scandals landed squarely in the middle of that process and shaped both its final text and the political will to enforce it.
- **The Snowden leaks (2013):** a former NSA contractor revealed mass, largely secret surveillance programs (including PRISM) run with the cooperation of major US technology companies — directly undermining citizen’s trust that data hosted on US-based servers was safe from US state actors.
- **The Cambridge Analytica scandal (2018, discovered just after GDPR’s adoption but during the run-up to enforcement):** a political consultancy harvested the data of up to 87 million Facebook users via a personality-quiz app and used it for psychographic ad targeting in the Brexit referendum and the 2016 US election — turning “data protection” from an abstract compliance topic into a story about elections being manipulated.
- Together, these two events reframed data protection publicly as a matter of democratic and national-security consequence, not just consumer inconvenience — which is the political context GDPR’s regulators have enforced within ever since.

Article 17, 20, 25 — and Their Costs

Architectural Translation

- Article 17 — Right to Erasure: storage must support true cascading deletion.
- Article 20 — Data Portability: structured, machine-readable export (JSON/XML) on request.
- Article 25 — Privacy by Design: systems must default to maximum privacy, not opt-in.
- Translation: retrofitting these is expensive — they must be built into the schema from day one.

Criticism & Ongoing Debate

- Compliance cost falls disproportionately on small companies vs. Big Tech — entrenching incumbents who can absorb the overhead.
- Cookie-consent banners are the most visible outcome — arguably a UX failure that undercuts the law's intent.
- Cross-border data transfer framework — determined on a case-by-case basis.
- Enforcement is uneven across national Data Protection Authorities, and appeals can take years — several of the fines on the next slide are still being contested.

Fines That Actually Landed on Big Tech

Cumulative GDPR fines exceeded €6 billion by 2026. Four representative cases:

Meta Platforms Ireland	€1.2 billion (2023)	Irish DPC — unlawfully transferring EU users' data to the US. The largest GDPR fine on record.
Amazon Europe	€746 million (2021)	Luxembourg CNPD — targeted advertising without a valid legal basis. Amazon appealed; a Luxembourg court annulled the fine in 2026 — a reminder these penalties aren't always final.
WhatsApp Ireland	€225 million (2021)	Irish DPC — failing to transparently disclose how user data was shared with other Meta group companies.
British Airways	£20 million (2020)	UK ICO — a cyberattack compromised 400,000+ customers' data due to inadequate security measures; reduced from an initial £183 million notice.

What Actually Drove the DPDP Act?

- Backdrop: A fight over the Indian state's data-collection ambitions. Starting in 2009, the government built Aadhaar — a biometric ID (fingerprints + iris scans) eventually covering over a billion residents — and progressively made it mandatory for welfare, banking, mobile SIM cards, and tax filing.
- **The Aadhaar Act (2016) was passed as a “Money Bill” — a procedural route that bypasses scrutiny in the Rajya Sabha (the upper house, where the government lacked a majority) — a move critics called an end-run around parliamentary oversight of a mass-surveillance-capable database being built without any data-protection law to constrain it.**
- Justice K.S. Puttaswamy (a former judge) had already challenged Aadhaar's constitutionality back in 2012, arguing that mandatory biometric enrollment without consent risked enabling a surveillance state. That single petition escalated all the way to a 9-judge Supreme Court bench.
- **In 2017, that bench unanimously ruled privacy a fundamental right under Article 21 — specifically because Aadhaar's expansion had outrun any legal framework protecting citizens' data. The Court explicitly tied recognition of the right to the need for “a carefully structured data protection regime,” which is the direct constitutional mandate that eventually produced the DPDP Act, six years later.**

Data Principals, Fiduciaries, and Government Carve-Outs

Architectural Translation

- Data Principal (citizen) & Data Fiduciary (processor) — key vocabulary.
- Purpose limitation: data collected for payment cannot be silently repurposed into an ML training pipeline without new consent.
- Verifiable, revocable consent: architecture needs auditable consent-token logs, not a one-time checkbox.
- Data localization: certain data flows are restricted from crossing borders — shapes multi-region architecture directly.

Criticism & Ongoing Debate

- Section 17 exemptions: government agencies can be exempted from the Act for sovereignty/security/public-order grounds — unreviewable by courts or Parliament.
- Critics (including Justice Srikrishna, who chaired the drafting committee) argue this fails the very necessity-and-proportionality test Puttaswamy established.
- No breach-compensation mechanism for individuals, unlike GDPR.
- Critics argue DPDP weakens the Right to Information Act by giving broad cover to withhold information as “personal data.”

Proportionality in Action: The 2018 Aadhaar Verdict

- In 2018, a 5-judge bench applied Puttaswamy’s fourfold test directly to Aadhaar itself — a rare, concrete example of “necessity and proportionality” actually deciding a real case rather than staying abstract.
- **Upheld: mandatory Aadhaar linkage for welfare subsidies and income-tax filing — the Court found a legitimate state aim (preventing leakage of public funds) and a proportionate means.**
- **Struck down: Section 57, which had let private companies (banks, telecoms) demand Aadhaar authentication — found disproportionate, since a private company verifying a customer’s identity has far less compelling a justification than the state administering welfare.**
- **Struck down: Section 33(2), which let intelligence officers access the Aadhaar database for national security without judicial oversight — failed the “procedural safeguards” prong for lacking any independent check on abuse.**
- *Worth noting for the DPDP debate: critics argue Section 17’s broad, unreviewable government exemptions look structurally similar to the Section 33(2) provision the Court struck down for Aadhaar just five years earlier.*

What Actually Drove HIPAA?

- The original driving problem was economic: in the early 1990s, Americans who changed jobs, or whose employer changed insurers, could be denied new health coverage entirely for a “pre-existing condition,” creating what economists called “job lock” — people staying in jobs they wanted to leave purely to keep insurance.
- In parallel, healthcare fraud was estimated at the time to consume roughly 10% of national health expenditure — billions of dollars — giving HIPAA’s original Title I (Health Insurance Portability) bipartisan momentum focused on portability and fraud, not on privacy.
- **The privacy and security rules came later when new issues were noticed — standardization of data formats to profile patients created privacy exposures needing its own safeguards.**

Audit Trails, RBAC, and the Coverage Gap

Architectural Translation

- Absolute audit logging: every single database read must be recorded, not just server errors — who looked at what, when.
- Role-Based Access Control down to the column level — a receptionist and a doctor see different fields of the same record.
- Business Associate Agreements: third-party cloud infrastructure can't be used unless the provider contractually certifies HIPAA-grade safeguards.

Criticism & Ongoing Debate

- Coverage gap: HIPAA only binds “covered entities” (hospitals, doctors, etc.) and their business associates — most consumer health apps, fitness trackers, and DTC genetic testing fall entirely outside it.
- Directly relevant to ML-for-healthcare research: a chest-radiograph model built outside a hospital's covered-entity boundary may not be HIPAA-governed at all.
- Compliance ≠ security: meeting the legal floor is not the same as good practice, but is often treated as if it were.

The Largest HIPAA Settlement on Record

Anthem, Inc.	\$16 million (2018)	HHS Office for Civil Rights — settled after a 2015 cyberattack (undetected spear-phishing) exposed the electronic health information of nearly 79 million people, the largest US health data breach on record. OCR found Anthem had failed to run an enterprise-wide risk analysis or monitor for intrusions.
Premiera Blue Cross	\$6.85 million (2020)	Phishing email -> Malware -> Leakage of medical records. HHS OCR — a 2015 breach exposing 10.4 million records; OCR cited failure to conduct adequate risk analysis before the breach occurred.
Advocate Health Care	\$5.55 million (2016)	Physical theft. The record-holder before Anthem — multiple incidents including stolen unencrypted laptops, showing physical device security is itself a HIPAA obligation.

What Actually Drove Section 230?

- **“Indecent” material reaching minors on the nascent internet, on the Prodigy public bulletin board: A court ruled that because Prodigy moderated some content on its message boards, it counted legally as a “publisher” and was therefore liable for everything else posted there — while a competitor that moderated nothing was treated as a mere “distributor” with far less liability.**
- That created a perverse incentive: platforms were legally safer not moderating at all than trying to remove some harmful content and being deemed to have taken on responsibility for the rest. Section 230’s “Good Samaritan” framing exists specifically to remove that penalty for trying.
- Most of the child development related actual indecency provisions were struck down as unconstitutional in *Reno v. ACLU* (1997) — Section 230 is the part of that 1996 moral-panic-era law that survived and ended up shaping the entire subsequent platform economy.

The Shield That Built the Modern Platform

Architectural Translation

- Core rule: interactive computer services are not treated as the “publisher” of third-party user content.
- If a user posts something illegal, the user is liable — not the platform hosting it.
- This is the legal precondition for automated content-moderation infrastructure at scale: filtering pipelines, report queues, moderation dashboards.
- Without it, platforms could not safely host user-generated content without pre-screening everything — which doesn’t scale.

Criticism & Ongoing Debate

- Bipartisan criticism from opposite directions: one side argues platforms under-moderate real harm; the other argues they over-moderate and 230 shields viewpoint-based censorship.
- Reform proposals span that whole range — PACT Act (transparency requirements), SAFE TECH Act (narrows immunity for paid content).
- DMCA (copyright act) goes through same conflict between “make platforms more liable” vs. “protect free expression”.

Section 230 in Front of the Supreme Court

Unlike GDPR or HIPAA, 230’s biggest test wasn’t a fine — it was whether the shield covers algorithmic recommendations at all.

Gonzalez v. Google	2023, US Supreme Court	Family of a Paris terror-attack victim argued YouTube’s recommendation algorithm actively promoting ISIS videos should lose 230 immunity, since recommending is different from merely hosting. The Court sidestepped the 230 question, resolving the case on other grounds — leaving the core issue undecided.
Doe v. Backpage / FOSTA-SESTA	2018 carve-out	Sex-trafficking litigation against Backpage.com exposed a gap 230 didn’t anticipate, leading Congress to carve out sex-trafficking liability — the first major narrowing of the immunity since 1996.

What Actually Drove the EU AI Act?

- The Commission's original 2021 proposal predates the generative-AI boom entirely — its real driver was a decade of documented harm from algorithmic decision-making in high-stakes government and corporate settings.
- **COMPAS (2016):** a US criminal-risk-scoring algorithm was shown by investigative journalists to rate Black defendants as higher-risk at nearly twice the rate of white defendants with similar records — becoming the reference case for “algorithmic bias with real liberty consequences.”
- **The Dutch childcare benefits scandal (“toeslagenaffaire,” 2019–2021):** a self-learning fraud-detection algorithm used dual nationality as a risk factor, wrongly accusing roughly 26,000 families of fraud, driving some into bankruptcy and over 1,000 children into foster care. The scandal brought down the entire Dutch cabinet in January 2021 — a government fell because of an unaudited algorithm.
- Then, mid-negotiation in 2022–23, the sudden mainstream arrival of GPT-3.5/4-class models forced a late redesign to add an entire General-Purpose AI category that didn't exist in the 2021 draft — the Act had to absorb a second, very different kind of risk while already being negotiated.

Four Risk Tiers, One Logging Requirement

Architectural Translation

- Unacceptable risk (banned): social scoring, manipulative techniques, real-time biometric ID in public spaces.
- High risk (heaviest obligations): risk management system, data-governance docs, human oversight, conformity assessment before market entry.
- Article 12 record-keeping: high-risk systems must automatically log events sufficient to trace a decision after the fact, E.g. hash-chained audit-log discussion.
- GPAI (training compute $> 10^{25}$ FLOPs) obligations: technical documentation, training-data summaries, copyright policies; “systemic risk” models also need adversarial testing.

Criticism & Ongoing Debate

- Compliance cost again concentrated on smaller players — large labs absorb conformity-assessment costs; startups and academic labs may struggle to.
- Innovation-vs-safety tension: critics argue the Act (plus the 2025 GPAI Code of Practice) risks pushing development outside the EU.
- The “high-risk” boundary has already moved once (GPAI added mid-negotiation) and is being renegotiated again.
- Very little enforcement case law yet — unlike GDPR’s decade of precedent, how strictly this will actually be applied is still unknown.

A Preview, Filed Under GDPR

The AI Act's high-risk obligations aren't enforceable yet — but regulators have already gone after exactly the systems it targets, using GDPR:

Clearview AI

**Fined in France,
Italy, Greece,
UK**

Scraped billions of facial images from the public web without consent to build a face-recognition search tool sold to law enforcement. Multiple EU/UK authorities issued fines and processing bans 2021–2023 — precisely the “real-time biometric identification” the AI Act now bans outright for public spaces.

Dutch Tax Authority

**€3.7 million
(2021)**

The Dutch DPA fined the tax service itself for unlawfully processing nationality data in the toeslagenaffaire algorithm (childcare benefits case) — a GDPR fine against the exact system that motivated the AI Act's high-risk category for public-benefits eligibility.

What the 2025 Code of Practice Actually Is

- Published by the EU AI Office on July 10, 2025, after a multi-stakeholder drafting process (Oct 2024 – Jul 2025, three drafts) — a voluntary compliance tool giving GPAI providers a concrete way to demonstrate they meet Articles 53 and 55, enforceable since 2 August 2025.
- Three chapters, matching the two-tier obligation structure from the mechanics slide: Transparency and Copyright apply to every GPAI provider; Safety & Security applies only to systemic-risk providers.

Transparency

All GPAI providers

- Standardized “Model Documentation Form” — training data, capabilities, energy use — shared with the AI Office and downstream integrators.

Copyright

All GPAI providers

- A copyright-compliance policy (incl. the Art. 4(3) text-and-data-mining opt-out) plus a contact point for rightsholder complaints.

Safety & Security

Systemic-risk providers only

- Ten commitments — adversarial testing, risk mitigation, incident reporting, cybersecurity — for an estimated 5–15 companies worldwide.

Legal Text → Architectural Reality: Next class

Legal requirement	Engineering translation
Right to be Forgotten (GDPR Art. 17)	Cascading deletion across shards / crypto-shredding
Purpose Limitation (DPDP)	Metadata tagging at ingestion for a policy engine to block unapproved queries
HIPAA §164.312 audit controls	Immutable, hash-chained audit trail + column-level RBAC
Data Localization (DPDP / PIPL)	Geo-sharded storage; quorum writes / consensus confined to region
Section 230 “Good Samaritan” moderation	Event-driven moderation pipelines, report queues, moderation APIs
AI Act Article 12 record-keeping	Automatic, tamper-evident event logging sufficient to reconstruct a decision

FURTHER READING

Student Reading List

GDPR (Regulation (EU) 2016/679)	<i>European Parliament & Council, 2016.</i>	Focus: Article 17 (Erasure) and Article 25 (Privacy by Design).
Justice K.S. Puttaswamy v. Union of India	<i>9-judge bench, Supreme Court of India, 2017.</i>	The fourfold necessity/proportionality test underlying DPDP.
The Digital Personal Data Protection Act, 2023	<i>Gazette of India.</i>	Data Principals, Fiduciaries, and §17 exemption penalties.
HIPAA Security Rule	<i>45 CFR Part 160 & Part 164, Subparts A and C.</i>	§164.312 Technical Safeguards: access, audit, integrity, transmission.
Section 230, 47 U.S.C. § 230	<i>U.S. Congress, 1996.</i>	Paragraph (c): “Good Samaritan” blocking and screening.
Regulation (EU) 2024/1689 (AI Act)	<i>European Union, 2024.</i>	Risk-tier definitions and Article 12 record-keeping obligations.